

Gestión de riesgos y análisis de impacto

Módulo 2

Mauricio Bustamante Garay

SESION 2

Consideraciones clave en Privacidad y Protección de Datos:

- Evaluaciones de Impacto a la Privacidad
- Elementos normativos
- Elementos organizativos (Ciclo de vida de los datos)
- Elementos culturales (Nivel de madurez en Privacidad de las personas)
-

Evaluación de impacto a la privacidad (PIA)

Una evaluación de impacto de privacidad (PIA) es un tipo de evaluación de impacto realizada por una organización, como una agencia gubernamental o una corporación, para determinar el impacto que un nuevo proyecto de tecnología, iniciativas o programas y políticas propuestos podrían tener en la privacidad de las personas. Establece recomendaciones para gestionar, minimizar o eliminar ese impacto.

Un objetivo clave del PIA es comunicar de manera efectiva los riesgos de privacidad de las nuevas iniciativas tecnológicas. También proporciona a los responsables de la toma de decisiones la información necesaria para tomar decisiones de política informadas basadas en una comprensión de los riesgos de privacidad y las opciones disponibles para mitigar esos riesgos.

Un PIA brinda beneficios a varias partes interesadas, incluida la propia organización iniciadora y sus clientes. Las implementaciones de PIA pueden ayudar a generar confianza con las partes interesadas y la comunidad de usuarios al demostrar la debida diligencia y el cumplimiento de las mejores prácticas de privacidad. Los problemas de privacidad que no se abordan adecuadamente pueden afectar la confianza de la comunidad en una organización, proyecto o política.

Elementos normativos y tecnológicos

Casos en los que se requiere una evaluación de impacto (Artículo 15 ter)

1. **Evaluación sistemática y exhaustiva de aspectos personales**, basada en decisiones automatizadas como la elaboración de perfiles, que produzcan efectos jurídicos significativos en los titulares de los datos.
2. **Tratamiento masivo o a gran escala** de datos personales.
3. **Monitoreo sistemático de zonas de acceso público**, mediante observación o vigilancia.
4. **Tratamiento de datos sensibles o especialmente protegidos**, en situaciones que no requieran consentimiento explícito.

Responsabilidades y regulaciones

- **El responsable del tratamiento** debe realizar la evaluación de impacto antes de iniciar operaciones, si existe un alto riesgo para los derechos de los titulares de los datos personales.
- **La Agencia de Protección de Datos Personales** establecerá y publicará una lista orientativa con los tipos de tratamiento que requieren evaluación.
- La Agencia también definirá criterios mínimos para la evaluación, incluyendo:
 - Descripción de las operaciones de tratamiento.
 - Finalidad del tratamiento.
 - Evaluación de la necesidad y proporcionalidad del tratamiento.
 - Evaluación de los riesgos asociados y las medidas de mitigación.
- Si el resultado de la evaluación determina que el tratamiento es de **alto riesgo**, el responsable puede solicitar recomendaciones a la **Agencia de Protección de Datos Personales** para gestionar adecuadamente los riesgos.

Principios de la Ley 21.719

1. **Licitud**: El tratamiento de datos personales debe realizarse conforme a la ley y respetando los derechos fundamentales de los titulares.
2. **Transparencia**: Los responsables del tratamiento deben informar de manera clara y accesible sobre el uso de los datos personales.
3. **Finalidad**: Los datos solo pueden ser utilizados para los fines específicos para los cuales fueron recolectados.
4. **Proporcionalidad**: El tratamiento de datos debe ser adecuado y limitado a lo estrictamente necesario para cumplir su finalidad.
5. **Calidad**: Los datos personales debe ser exactos, completos y actuales en relación con la finalidad del tratamiento, lo que obliga al responsable a rectificar o suprimir los datos en casos que sean inexactos o erróneos.
6. **Seguridad**: Se deben aplicar medidas técnicas y organizativas para proteger los datos contra accesos no autorizados, pérdidas o alteraciones.
7. **Responsabilidad**: Los responsables del tratamiento deben garantizar el cumplimiento de la ley y demostrar que han tomado medidas adecuadas para proteger los datos.
8. **Confidencialidad**: Se debe garantizar la privacidad de los datos personales y evitar su divulgación indebida.
9. **Derechos del titular**: Las personas tienen derecho a acceder, rectificar, cancelar y oponerse al tratamiento de sus datos personales. También tienen derecho a solicitar la transferencia de sus datos de un responsable a otro.
10. **No discriminación**: El uso de datos personales no debe generar prácticas discriminatorias o afectar derechos fundamentales.

Elementos normativos y tecnológicos

Categorías generales de las obligaciones emanadas de la ley 21.719

Accesos a información	Política de Privacidad	Derechos ARCOP
Cesión de datos	Consentimiento	Retención/destrucción
Privacy by Design	Reporte de incidentes	Seguridad de los datos
Tratamiento de terceros	Datos Transfronterizos	

 Categorías evaluables en un PIA

 Estándar organizacional

Beneficios

Un PIA proporciona una forma para que una organización demuestre compromiso y respeto por la privacidad del usuario.

Otros beneficios clave incluyen:

- Reduce los costos futuros en gastos legales, daños a la reputación y publicidad negativa potencial, al considerar los problemas de privacidad al principio de un proyecto.
- Demuestra a los empleados, proveedores, clientes y ciudadanos que su organización se compromete a proteger y defender los derechos de privacidad.
- Proporciona una manera de detectar y mitigar los problemas de privacidad antes de que ocurran para evitar errores de privacidad costosos o vergonzosos.
- Proporciona evidencia de que una organización intentó prevenir los riesgos de privacidad.
- Ayuda a cumplir o demostrar cumplimiento a las normas y leyes vigentes

Fases de un PIA

En la actualidad no existe un estándar único para las evaluaciones de privacidad. Sólo existen guías y lineamientos reconocidos respecto a cómo elaborarlos. Sin embargo, sí existe un acuerdo común en cuatro grandes fases para la elaboración de un PIA:

- Recolección de antecedentes
 - Entender
- Evaluación y análisis de riesgo
 - Descubrir riesgos y mitigarlos
- Documentación del caso
 - Formalizar
- Cierre y seguimiento
 - Ciclo evolutivo

Etapas para la realización de un PIA

Recolección de antecedentes (Contexto)

1. Iniciación del Proyecto
2. Detalles del Proyecto
3. Identificación y Consulta con las Partes Interesadas
4. Ciclo de vida de los Datos

Evaluación y análisis de riesgo (Gestión de riesgos)

1. Evaluación de la Necesidad y Proporcionalidad
2. Evaluación de Riesgos
3. Controles y medidas de mitigación

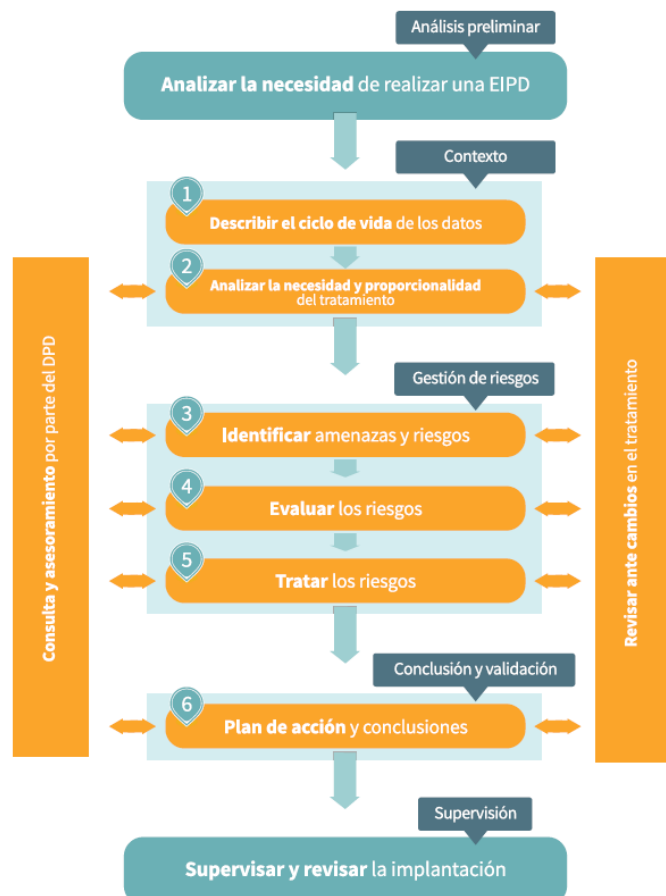
Documentación del caso (Conclusión y validación)

1. Documentación detallada y clasificación de sensibilidad y riesgo residual
2. Reportes y formalización de planes de acción

Cierre y seguimiento (Supervisión)

1. Revisión y Aprobación
2. Monitoreo y Revisión Continua

Etapas para la realización de un PIA



■ Contexto:

1 Describir el ciclo de vida de los datos: Descripción detallada del ciclo de vida y del flujo de datos en el tratamiento. Identificación de los datos tratados, intervinientes, terceros, sistemas implicados y cualquier elemento relevante que participe en la actividad de tratamiento.

2 Analizar la necesidad y proporcionalidad del tratamiento: Análisis de la base de legitimación, la finalidad y la necesidad y proporcionalidad del tratamiento que se pretenden llevar a cabo.

■ Gestión de riesgos:

3 Identificar amenazas y riesgos: Identificación de las amenazas y riesgos potenciales a los que están expuestas las actividades de tratamiento.

4 Evaluar los riesgos: Evaluación de la probabilidad y el impacto de que se materialicen los riesgos a los que está expuesta la organización.

5 Tratar los riesgos: Respuesta ante los riesgos identificados con el objetivo de minimizar la probabilidad y el impacto de que estos se materialicen hasta un nivel de riesgo aceptable que permita garantizar los derechos y libertades de las personas físicas.

■ Conclusión y validación:

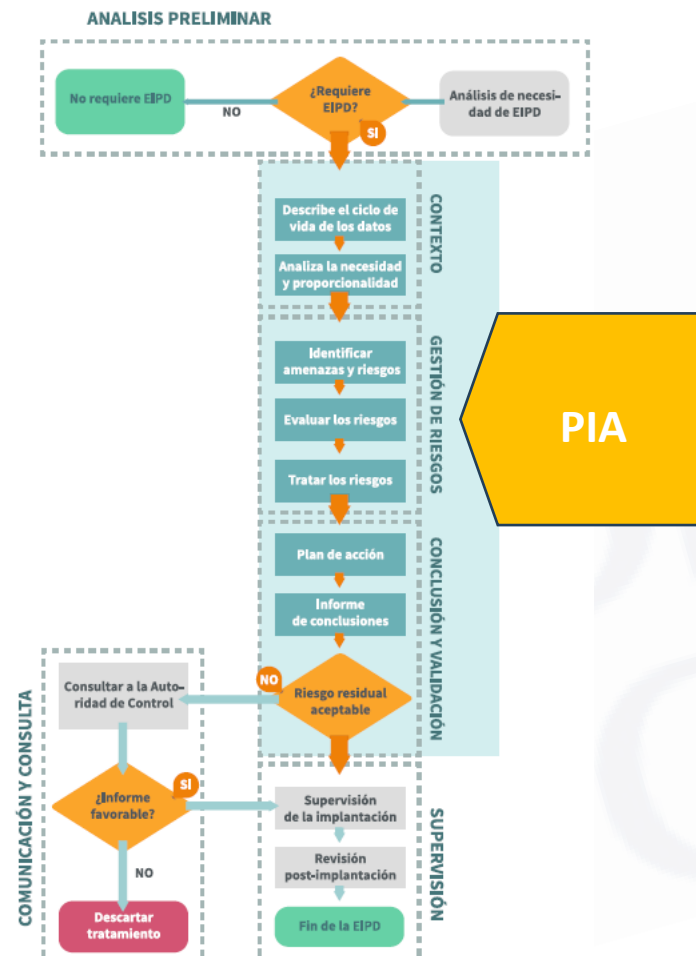
6 Plan de acción y conclusiones: Informe de conclusiones de la EIPD donde se documente el resultado obtenido junto con el plan de acción que incluya las medidas de control a implantar para gestionar los riesgos identificados y poder garantizar los derechos y libertades de las personas físicas y, si procede, el resultado de la consulta previa a la autoridad de control a la que se refiere el **artículo 36 del RGPD**.

Roles y Responsabilidades para un PIA



FASE	Responsable del tratamiento	DPD	Encargado del tratamiento	Otras áreas relevantes (pe seguridad, riesgos, Asesoría Jurídica, ...)
1 Describir el ciclo de vida de los datos	R/A	C/I	C	C
2 Analizar la necesidad y proporcionalidad del tratamiento	R/A	C/I	C	C
3 Identificar amenazas y riesgos	R/A	C/I	C	-
4 Evaluar los riesgos	R/A	C/I	C	-
5 Tratar los riesgos	R/A	C/I	C	C
6 Plan de acción y conclusiones	R/A	C/I	C	C

Metodología para realizar un PIA



Una evaluación PIA debe ser un instrumento formal y de aceptación por parte de la organización. En la mayoría de los casos un PIA es firmado por las partes interesadas. Esto demuestra la aceptación del riesgo residual por parte de la primera línea, quienes son los dueños de los riesgos en una organización.

Los controles mitigadores de riesgos también deben ser aceptados y formalizados por los responsables (pueden ser varios) y los plazos comprometidos.

Mientras no se cumplan los plazos el riesgo inherente se mantiene abierto y esto es parte de lo que la primera línea acepta.

Ciclo de Vida de los datos

El ciclo de vida de los datos es un proceso que abarca desde la generación de los mismos hasta su eliminación. Comienza con la recolección de datos, ya sea a través de formularios, sensores u otros medios. Una vez recopilados, estos datos pasan a la etapa de almacenamiento, donde se guardan en bases de datos o sistemas de almacenamiento en la nube.

A medida que los datos se utilizan y se analizan, se vuelven cada vez más valiosos. Es en esta etapa donde se pueden aplicar técnicas de minería de datos y análisis estadístico para extraer información relevante. **El conocimiento obtenido a partir de estos análisis puede ser utilizado para tomar decisiones informadas y mejorar procesos y servicios.**

Sin embargo, los datos también tienen un periodo de vida útil. A medida que pasa el tiempo, los datos pueden volverse obsoletos o perder su relevancia. Es por eso que es necesario incluir una etapa de eliminación de datos en el ciclo de vida. **La eliminación adecuada de los datos es crucial para proteger la privacidad y la seguridad de las personas involucradas.**

Tabla para documentar un ciclo de vida

		FASES				
		<i>Captura de datos</i>	<i>Clasificación / Almacenamiento</i>	<i>Uso / Tratamiento</i>	<i>Cesión o transferencia de los datos a un tercero</i>	<i>Destrucción</i>
ETAPAS	<i>Actividades del proceso</i>					
	<i>Datos tratados</i>					
	<i>Intervinientes involucrados</i>					
	<i>Tecnologías intervinientes</i>					

Fases del Ciclo de Vida de los datos

En el ciclo de vida de los datos existen diferentes fases que deben ser consideradas en el marco de una evaluación de riesgos de privacidad, ya sean de flujos pre-existentes o en el diseño de soluciones tecnológicas que incorporarán nuevos flujos de datos dentro de la organización.

Estas fases no siempre están presentes en un proceso, flujo o iniciativa, sin embargo, al menos la fase de procesamiento deberá estar presente ya que la mayoría de las regulaciones considera el procesamiento de datos personales como el acto más básico que se pueda realizar con un dato, incluyendo la acción de observarlo, desplegarlo, moverlo o guardarlo.

La recomendación es que toda organización cuente con un inventario de datos personales y ojalá que además cuenten con un catálogo de flujos de datos detallado, ya sea indexado a las aplicaciones o a los flujos de proceso. Las matrices RAT son fundamentales para este entendimiento.

Fase de Recopilación

La primera fase del ciclo de vida de los datos personales es la **recopilación**. En esta etapa, nuestros datos son recopilados por diferentes entidades, ya sea a través de formularios en línea, aplicaciones móviles o cualquier otra interacción digital. Es importante ser conscientes de qué datos estamos proporcionando y con qué propósito se utilizarán.

En otro ámbito también podemos recopilar datos que nosotros mismos hemos comprado y mantenemos almacenados.

La recopilación de datos puede provenir desde el propio titular, desde fuentes externas o desde fuentes internas.

En este punto y como valor a los catálogos que la empresa mantenga, es clave entender que tipo de titular está detrás de los datos que recopilamos ya que en función de eso podremos administrar mejor la sensibilidad de los datos.

Ej: No es lo mismo recopilar datos de clientes que de referidos.

Fase de Almacenamiento

La siguiente fase es la de **almacenamiento**. Una vez que nuestros datos son recopilados, son almacenados en diferentes bases de datos o servidores. Es crucial asegurarnos de que estas bases de datos estén protegidas y que solo las entidades autorizadas tengan acceso a ellos.

Así mismo, es crucial entender el lugar físico y tipo de persistencia que mantendrán los datos almacenados ya que en función de eso se podrán determinar otros riesgos de privacidad como por ejemplo, los riesgos de almacenamiento en países que no son considerados adecuados.

Otro aspecto importante es que el almacenamiento va más allá de una base de datos, ya que incluso el correo electrónico puede considerarse una fuente de almacenamiento en el caso de que existan malas prácticas como el envío de interfaces a través de correo.

Fase de procesamiento/tratamiento

Después viene la fase de **procesamiento o tratamiento** de los datos. Durante esta etapa, nuestros datos son utilizados para diferentes fines, como marketing directo, análisis de mercado, personalización de servicios o toma de decisiones. Es importante tener control sobre cómo se utilizan nuestros datos y demostrar una base de licitud ante este tratamiento.

El concepto de procesamiento se ha ido ampliando en el tiempo y hoy la visualización de un dato en pantalla es considerado un acto de procesamiento toda vez que con dicha visualización se puede tomar una decisión sobre dicho elemento.

Es clave tener claridad respecto a las finalidades para las cuales son requeridos los datos, de esta forma, el procesamiento deberá ser asociado al menos a una de dichas finalidades ya previamente validadas y aceptadas como legítimas dentro de la empresa.

Fase de transmisión

La fase siguiente es la **transmisión** de los datos. En este punto, nuestros datos pueden ser transferidos a terceros, como empresas asociadas o proveedores de servicios. Debemos asegurarnos de que estas transferencias se realicen de manera segura y que nuestros datos estén protegidos durante el proceso.

Tener un registro de los lugares hacia donde se transmite la información es clave a la hora de hacer cumplir los derechos de los titulares dentro de una empresa.

Lo anterior es clave sobre todo ya que las regulaciones más robustas exigen SLA de atención en la respuesta de los derechos ARCO y no conocer, de forma organizada, donde se encuentran propagados los datos de la organización podría acarrear tiempos excesivos en la respuesta a las solicitudes de los titulares, poniendo a la organización en riesgo de potenciales multas de parte del regulador de datos.

Fase de eliminación

Finalmente, llegamos a la fase de **eliminación** de los datos. En algún momento, nuestros datos dejarán de ser necesarios y deben ser eliminados de forma segura. Es importante asegurarnos de que nuestros datos sean eliminados de manera permanente y que no queden rastros de ellos en ninguna base de datos o servidor.

La eliminación de datos también puede tener un enfoque basado en datos en línea o datos fuera de línea. Es crucial en esta etapa definir políticas de retención y eliminación con el fin de establecer parámetros claros y de bajo riesgo para la organización en cuanto a la eliminación de los datos.

Eliminar datos que no debían eliminarse también representa un riesgo, por eso las políticas deben considerar ambos enfoques, el de retención y el de eliminación (escalonada o directa)

Etapas del tratamiento

Adicionalmente, para cada una de las etapas del ciclo de vida de los datos en las actividades de tratamiento, se deben identificar todos los elementos involucrados en cada una de las etapas. Podríamos clasificar los elementos involucrados en las siguientes categorías:



Etapa: Reconocer actividades y operaciones

En la práctica, puede identificarse un tratamiento como el conjunto de operaciones dirigidas a conseguir una determinada finalidad que se legitiman en una misma base jurídica. Cada tratamiento incluirá una serie de operaciones como, por ejemplo, la recogida, registro, organización, estructuración, consulta o utilización de los datos.

Una actividad de tratamiento de datos se debe incluir en el registro de actividades en el momento previo antes de su puesta en marcha. Para facilitar la documentación del registro se puede utilizar la información previa documentada en los análisis iniciales realizados durante la fase de definición del tratamiento.

Una actividad u operación puede considerarse, por ejemplo, la captura de datos mediante un formulario web, el filtrado de información mediante un proceso de perfilado, un proceso de cifrado, el borrado o cualquier tarea que requiera el tratamiento o manipulación de los datos.

Etapa: Clasificar o categorizar los datos

El ciclo de vida está directamente relacionado con los datos de carácter personal que se tratan. Se deben identificar y categorizar los datos de carácter personal tratados o manipulados durante el tratamiento vigilando siempre que los mismos correspondan a los principios que dicta la normativa vigente. Para cada tipología de datos, se debe establecer su categoría y su grado de importancia dentro de las actividades de tratamiento, determinando si es imprescindible o no.

Es recomendable que la organización establezca un lenguaje estandarizado para categorizar los datos personales. Esta categorización puede ser de muy alto nivel o del más bajo nivel, tanto como suponga el riesgo detrás del tratamiento de los datos.

Por ejemplo, se puede categorizar la información como: PII, SPII y HSPII o bien se puede categorizar como de identificación directa o identificación indirecta, de contactabilidad, etc.

Los ejemplos anteriores no requieren que sean excluyentes ya que incluso se pueden definir categorías mixtas.

Etapa: Identificar a los intervinientes

Durante todo el ciclo de vida de los datos pueden existir numerosos intervinientes que participen en las actividades de tratamiento.

Se deben identificar a las personas físicas o jurídicas que, de manera individual o colectiva, están implicadas en el desarrollo de las actividades del tratamiento de los datos de carácter personal. A la hora de identificar a los diferentes intervinientes, es necesario tener en cuenta todos los flujos de información de los datos previstos en el tratamiento.

Los intervinientes en el tratamiento deben estar identificados y tener delimitadas sus funciones y responsabilidades.

Los roles de los intervinientes pueden ser: Responsable del tratamiento de datos, encargado del tratamiento de datos, usuarios consumidores de datos, data stewards, etc.

Etapa: Identificar las tecnologías

La tecnología y los sistemas son una capa clave que da soporte a las actividades de tratamiento de los datos de carácter personal. Se deben identificar aquellos elementos tecnológicos que intervienen en las actividades de tratamiento de los datos de carácter personal a un alto nivel, sin llegar entrar en un análisis tecnológico pormenorizado.

Dentro de cada etapa se debe identificar el hardware y el software que sea relevante desde la perspectiva del tratamiento de los datos de carácter personal. Las tecnologías están expuestas a diferentes riesgos, por ello, es fundamental realizar una adecuada identificación de todos los elementos tecnológicos que intervienen a lo largo del ciclo de vida de los datos asociados al tratamiento. Se debe identificar la tecnología (cloud, BBDD, servidores), aplicaciones, dispositivos y técnicas empleadas en el procesamiento de los datos.

Es clave considerar que si una actividad implica tratamiento no automatizado o digital, este igualmente debe ser considerado y documentado.

Ejemplo 1

un paciente llega a una clínica y su información es registrada en el sistema. A lo largo de su tratamiento, estos datos pasan por diferentes **fases del ciclo de vida de los datos**

Ejemplo 1

		Captura de datos	Clasificación/Almacenamiento	Uso/Tratamiento	Cesión/Transferencia a tereros	Destrucción
EATAPAS	Actividades del proceso	Registro de datos personales del paciente.	Fichas clínicas digitales. Segmentación por tipo de atención.	Consulta de antecedentes médicos e información personal del paciente.	Envío de informes médicos a hospitales o aseguradoras.	Eliminación o anonimización de registros.
	Datos Tratados	Nombre, RUT, contacto, historial médico.	Datos estructurados en bases de datos organizacional	Opción de perfil del paciente y opción ficha clínica	Solo datos estrictamente necesarios para la finalidad autorizada	Datos eliminados o anonimizados según normativa.
	Intervinientes	Recepcionista, paciente, médico tratante.	Administradores de sistemas, responsables de protección de datos.	Médicos, enfermeros, especialistas.	Instituciones de salud, aseguradoras, investigadores autorizados.	Responsable de datos, equipos de seguridad informática.
	Tecnologías	Formularios digitales, CRM, bases de datos	Servidores seguros, almacenamiento en la nube, base de datos SQL-Server	Sistemas de SysMed	Redes seguras, protocolos de intercambio de datos cifrados como SFTP o similar	Algoritmos de eliminación segura, técnicas de anonimización

Ejercicio 1

Cuando un cliente reserva una habitación en un hotel, su información pasa por distintas fases y etapas en el ciclo de vida de los datos.

Ejercicio 1

		FASES				
		Captura de datos	Clasificación/Almacenamiento	Uso/Tratamiento	Cesión/Transferencia a tereros	Destrucción
EATAPAS	Actividades del proceso	Registro de la reserva vía web, teléfono o presencial	Ficha del hoesped	Validación de identidad, asignación de habitación, cobros, notas especiales, revisar historial	Plataformas de pago, agencias de viaje, autoridades si corresponde	Eliminación o anonimización una vez cumplida la finalidad más 5 años
	Datos Tratados	Nombre, rut o pasaporte, contacto, fechas de estadía, preferencias, métodos de pago.	Historial de reservas, historial de pagos	Opción Hoespedes del sistema de registro, DataWarehouse para revisar historial del hoesped.	Datos de métodos de pago, fechas, y datos estrictamente necesario en caso de informar a autoridades.	Se elimina la ficha del hoesped y todos dud historiales
	Intervinientes	Cliente, recepcionista o personal de reservas.	Personal TI, administrativos, encargados de fidelización y marketing	Recepcionistas, área de Analytcs, área de servicio al cliente.	Visa/Master, Agencias de viaje asociadas, PDI	Eliminación automática, no se permite el borrado por usuarios.
	Tecnologías	Formulario we, teléfono o sistema de reservas.	Base de datos Oracle en plataforma SaaS	Software eHotels	SFTP o pasarlea de pago	Algoritmo de eliminación

Ejercicio 2

Una empresa contrata a un empleado y por lo tanto se recopila y maneja información personal para diferentes fines administrativos. Que matriz de ciclo de vida de datos se podría proponer?

Ejercicio 2

		FASES				
		Captura de datos	Clasificación/Almacenamiento	Uso/Tratamiento	Cesión/Transferencia a terceros	Destrucción
EATAPAS	Actividades del proceso	Se recoge información personal en el proceso de contratación.	Se almacenan datos en sistemas internos de gestión de empleados	Se usan los datos para pagos, evaluaciones de desempeño y beneficios laborales.	Se comparten ciertos datos con entidades externas como bancos o AFP.	Eliminación o anonimización de datos tras la desvinculación o al cumplirse el plazo legal de retención.
	Datos Tratados	Nombre, RUT, dirección, antecedentes laborales, datos bancarios	Registros digitales en el sistema de recursos humanos.	Información sobre nómina, desempeño y beneficios del empleado	Datos financieros y laborales enviados a instituciones externas según necesidad.	Eliminación de cuentas o anonimización de datos personales en sistemas.
	Intervinientes	Recursos Humanos, el empleado, directivos de la empresa.	Administradores de bases de datos, equipo de TI de la empresa.	Recursos Humanos, gerentes de área, contabilidad.	Bancos, aseguradoras, entidades gubernamentales.	Equipo de seguridad informática, cumplimiento legal.
	Tecnologías	Formularios de contratación, plataformas de gestión de talento.	Bases de datos corporativas con cifrado y accesos restringidos.	Software de gestión de recursos humanos, plataformas de nómina.	APIs bancarias, redes seguras de intercambio de datos.	Algoritmos de eliminación segura, técnicas de anonimización.